TÁCTICAS DE OSINT

LO QUE INTERNET SABE DE TI
(Y TÚ NO SABÍAS)

TROPICON

by
omespino@cozumel:~/ tropicon $

ACERCA DE MÍ

Omar Espino

Consultor de Seguridad en Websec

WEBSEC

Bug Bounty Hunter

Google

Microsoft

slack

NOKIA

ATLASSIAN

YAHOO!

SONY

Twitter (X): @omespino
Blog Personal: omespino.com

Email: omespino@websec.mx

AGENDA

omespino@cozumel~/tropicon$ cat agenda.txt

- Introducción
  - Introducción a la huella digital
  - Explotación de fuentes públicas
  - Listado de herramientas especializadas
  - Correlación y Pivoting
  - Higiene digital y mitigación
- Q&A

¡ATENCIÓN!

Toda la información incluida en este medio es para fines educativos y profesionales, en ningún caso los organizadores de este evento, ni yo, somos responsables de cualquier mal uso de esta información.

Queda estrictamente prohibido tomar fotos o video durante la presentación.

INTRODUCCIÓN

Que SÍ es OSINT

- Fuentes de acceso público
- Análisis de metadatos
- Búsquedas avanzadas
- Monitoreo de redes sociales
- Consulta de registros públicos
- Geolocalización
- Uso de Archivos Históricos
- Correlación de Identidades
- Siempre en el marco de lo LEGAL

Que NO es OSINT

- Ingenieria Social
- Deep Web
- Intrusión en la Privacidad
- Vigilancia Física
- Trashing
- Robo de información
- Extorción
- Interceptar de comunicaciones
- Espionaje
- Uso de Info. confidencial
- Cualquier cosa ILEGAL

INTRODUCCIÓN A LA HUELLA DIGITAL

INTRODUCCIÓN A LA HUELLA DIGITAL

Tipos de Huella Digital

Huella Activa: Datos que el usuario comparte de forma deliberada.

Publicaciones en redes sociales, correos enviados, comentarios en foros o formularios completados.

Huella Pasiva: Datos que se recolectan sin que el usuario sea consciente de ello.

Direcciones IP, historial de navegación, cookies de rastreo y geolocalización en segundo plano.

INTRODUCCIÓN A LA HUELLA DIGITAL

Metadatos (La huella invisible)

Los metadatos son " datos sobre los datos ". Es información oculta en archivos que puede revelar:

Imágenes (EXIF): Coordenadas GPS exactas, modelo del dispositivo y fecha/hora.

Documentos (PDF/Docx): Nombres de usuarios internos, versiones de software y rutas de servidores.

INTRODUCCIÓN A LA HUELLA DIGITAL

Identificadores Únicos

Reutilización de Cuentas: Uso del mismo username o alias en múltiples plataformas, facilitando la correlación de identidades.

El internet nunca olvida

Perpetuidad: Una vez que la información llega a la red, escapa del control del autor (caché de buscadores, Wayback Machine).

Geolocalización

Identificación de ubicaciones físicas mediante el análisis de elementos visuales, registros de conexión o coordenadas GPS incrustadas en archivos.

EXPLOTACIÓN DE FUENTES PÚBLICAS

EXPLOTACIÓN DE FUENTES PÚBLICAS

Google DORKS

site:*.example.com ext:pdf/doc "busqueda"

Sitios Gubernamentales (México)

Redes Sociales

Mapas

EXPLOTACIÓN DE FUENTES PÚBLICAS

Ejercicios prácticos:

- Consulta con un profesionista (Psicólogo, Dentista, etc)
- Compraventa de un automóvil
- Inversión en desarrollo inmobiliario
- Obteniendo el nombre real de un "Influencer / Streamer"
- Validación de Facturas (SAT)
- Determinar la ubicación donde fue tomada una foto
- Consultar nóminas de gobierno ("Transparencia")

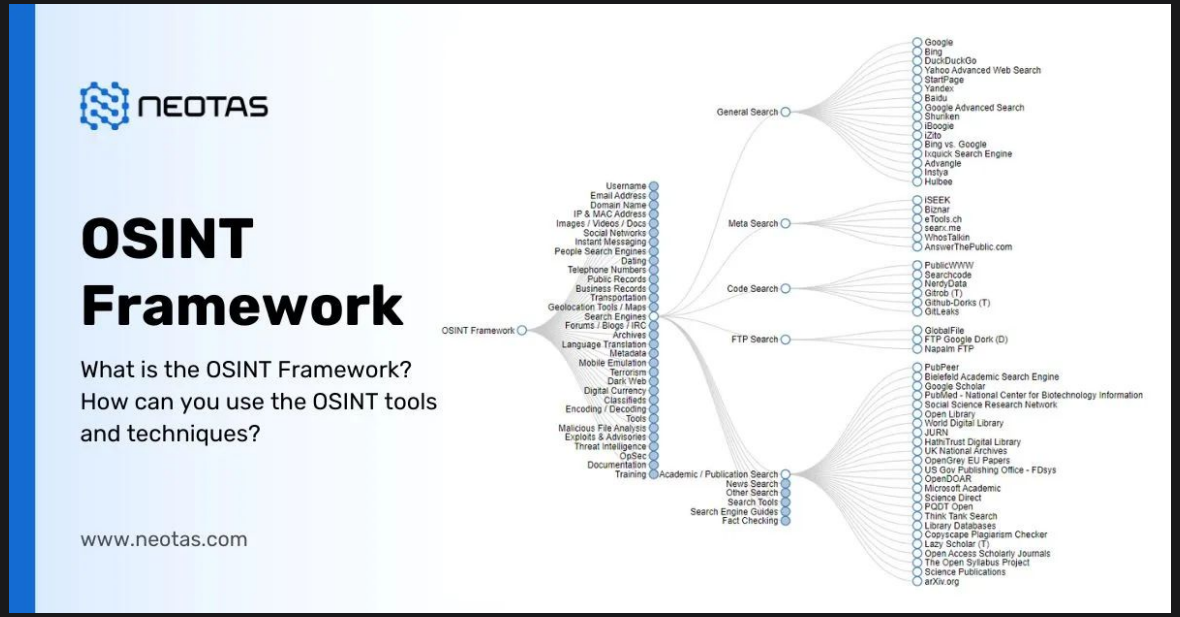
BREAK

10 MIN.

LISTADO DE HERRAMIENTAS ESPECIALIZADAS

LISTADO DE HERRAMIENTAS ESPECIALIZADAS

OSINT FRAMEWORK



CORRELACIÓN Y PIVOTING

CASO PRÁCTICO

[Inteligencia sobre un target real]

CORRELACIÓN Y PIVOTING

El objetivo del ejercicio es simple, vamos a ver que tanta información podemos obtener de la empresa X con las técnicas mencionadas anteriormente

CORRELACIÓN Y PIVOTING

- Partimos del nombre de la empresa
- Organigrama / Empleados
- Sujetos en específico
- Uniforme
- Gafete
- Documentación Interna / Formatos de visita
- Listado de proveedores
- Email del CEO
- Mapeo de infraestructura y tecnologías utilizadas

HIGIENE DIGITAL Y MITIGACIÓN

HIGIENE DIGITAL Y MITIGACIÓN

Gestión de Huella Digital en Google

Derecho al Olvido (Motivos Legales):
https://support.google.com/legal/troubleshooter/1114905

Información de Identificación Personal (PII):
https://support.google.com/websearch/answer/9673730

Herramienta "Resultados sobre ti" (Dashboard):
https://myactivity.google.com/results-about-you

Contenido Obsoleto (Caché):
https://search.google.com/search-console/remove-outdated-content

Reporte de Doxing:
https://support.google.com/websearch/contact/content_removal_form

Imágenes Íntimas sin Consentimiento:
https://support.google.com/websearch/answer/6302812

HIGIENE DIGITAL Y MITIGACIÓN

Gestión de Huella Digital en portales de México

REPEP (PROFECO): Inscripción para bloquear llamadas publicitarias de empresas de comercio, telecomunicaciones y servicios.

https://repep.profeco.gob.mx/registrar_telefono.jsp

REUS (CONDUSEF): Registro para evitar publicidad y acoso telefónico de instituciones financieras (bancos, seguros, Afores).

https://www.gob.mx/tramites/ficha/registro-publico-de-usuarios-reus-para-personas-fisicas/CONDUSEF2536

Derechos ARCO (INAI): Gestión de solicitudes para el Acceso, Rectificación, Cancelación y Oposición de datos personales ante cualquier entidad pública o privada.

https://www.plataformadetransparencia.org.mx

https://home.inai.org.mx/?page_id=3402 (Guía oficial del INAI para titulares)

HIGIENE DIGITAL Y MITIGACIÓN

Cosas básicas que podemos hacer (todo suma)

- Se recomienda utilizar un número de teléfono personal y otro laboral (cada vez es más fácil con ESIM)

- Higiene de identidad en internet: Uso de alias de correo para segmentar registros y detectar fugas de datos, además de utilizar alias distintos en redes sociales. (omespino+alias1@gmail.com , omespino+alia2@gmail.com)

- Eliminación de metadatos EXIF en imágenes antes de compartirlas en plataformas públicas como Marketplace o LinkedIn.

https://exifremover.com

Q&A

ありがとう
ARIGATŌ

GRAZIE

DANKE

DANKON

धन्यवाद

GRACIAS

MERCI

谢谢
XIÈXIÈ

감사합니다

СПАСИБО

THANK YOU